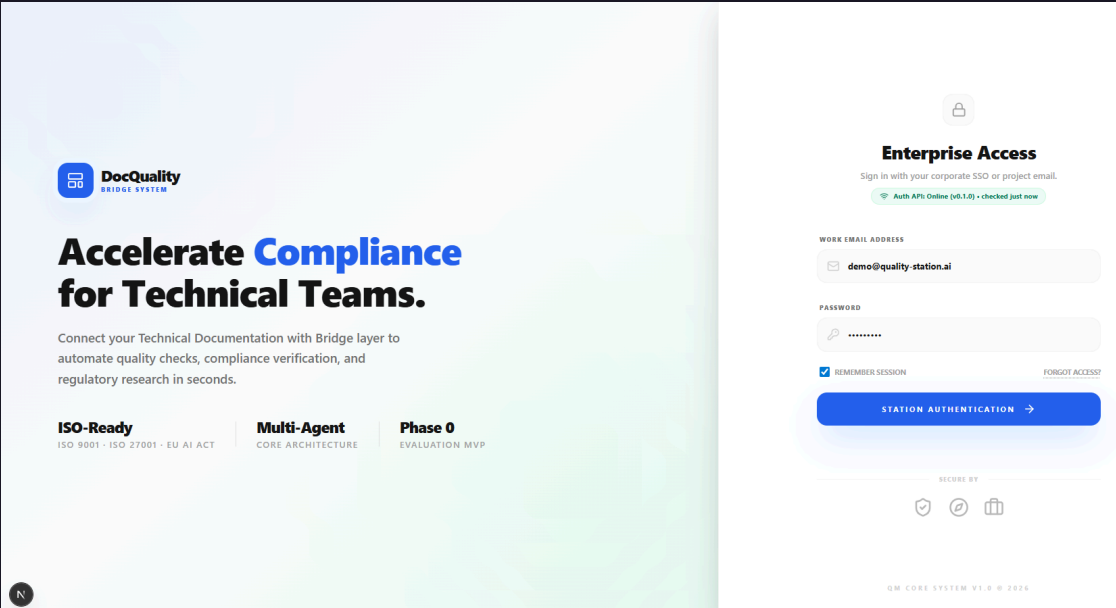


Documentation Quality Compliance Checker

Ilona Brinkmeier · Wiebke Meyer · Carol Willing

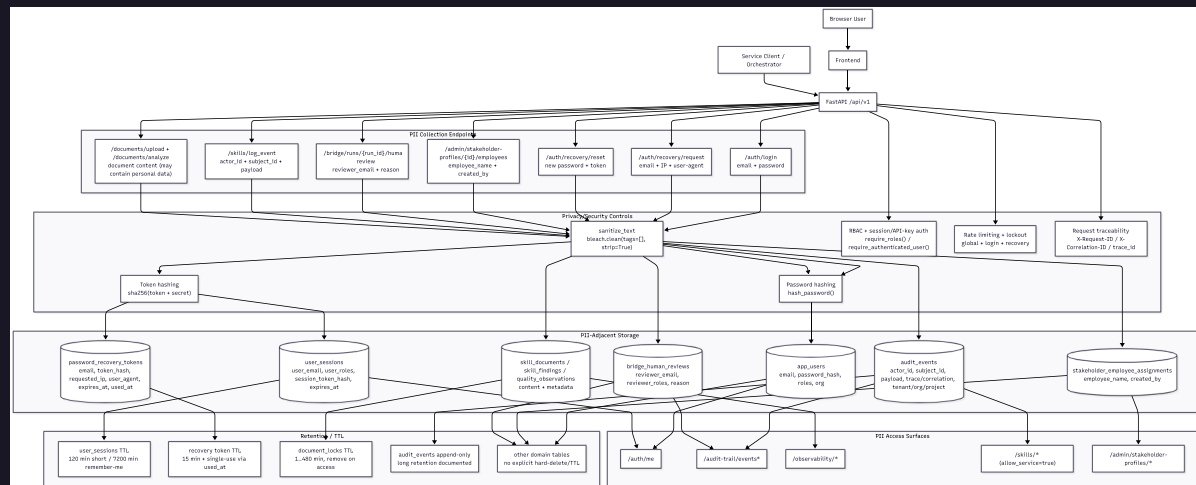


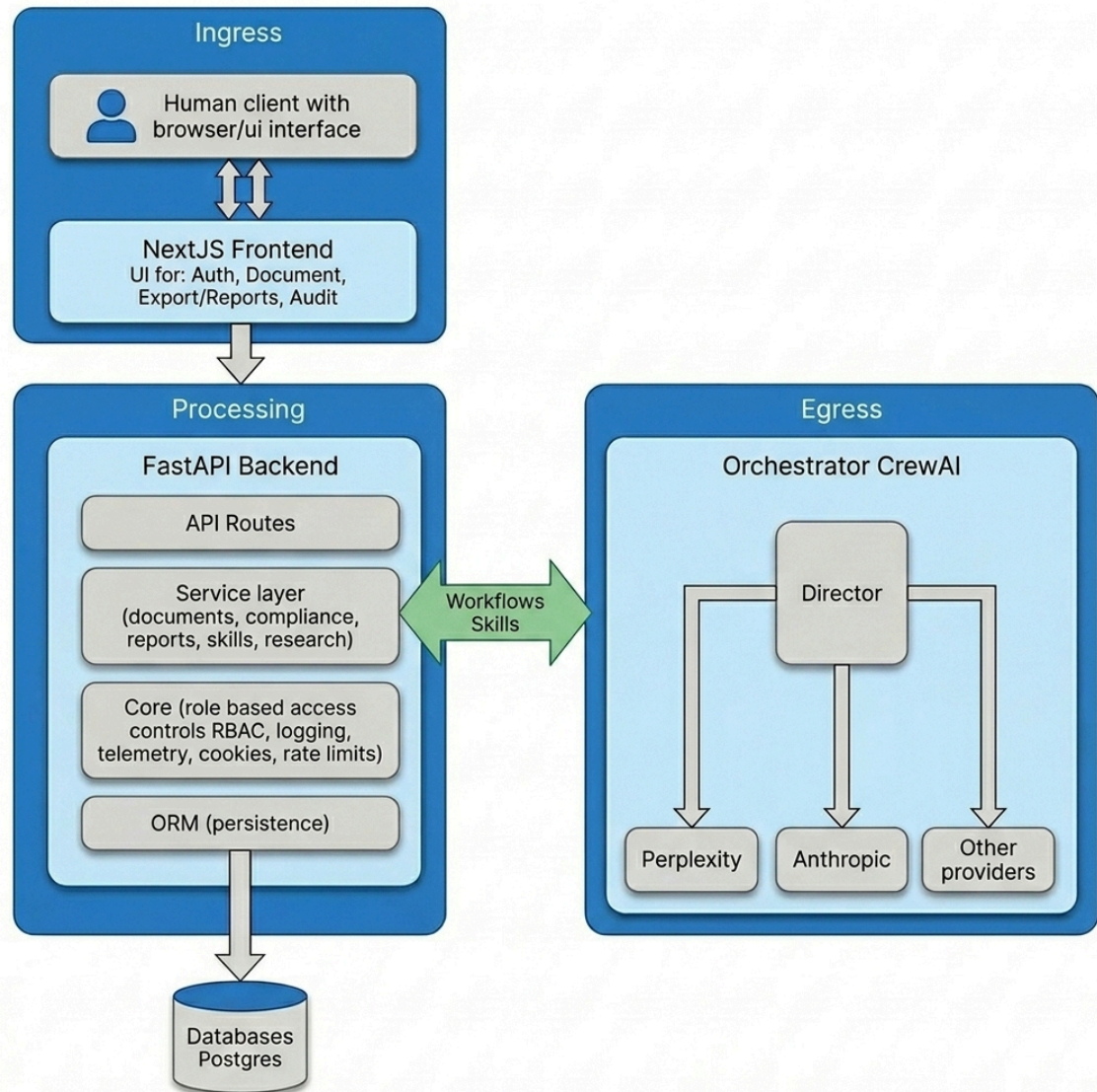
Project & use case

- What we audited
- Problem solved
- Architecture at a glance
- Why privacy matters

What we audited

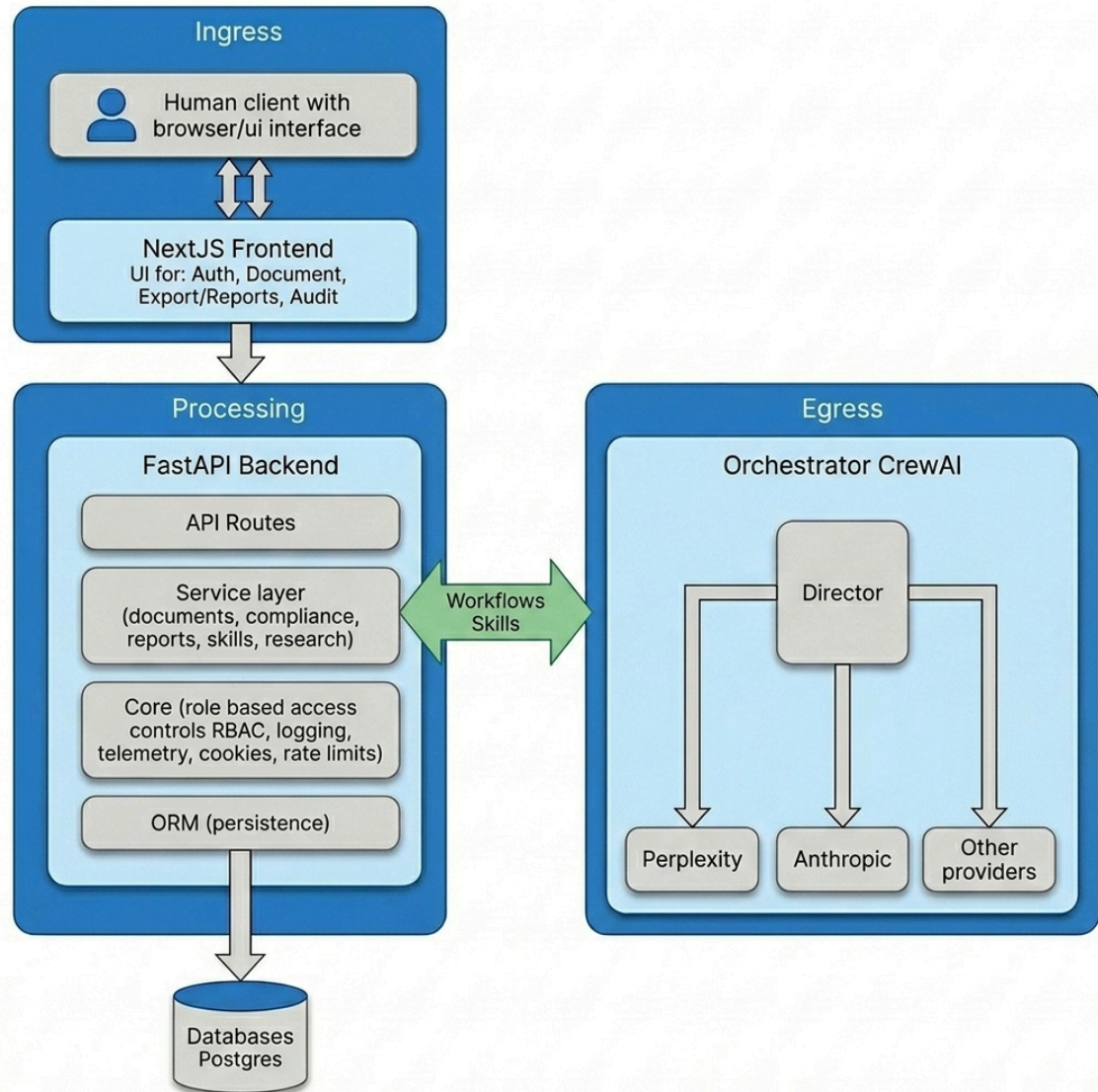
- **Scope:** Documentation quality compliance checker performs AI-assisted QM audits of technical docs and governance docs (SOPs)
- **Repo:** https://github.com/IloBe/doc_quality_compliance_check
- **Audit:** <https://willingc.github.io/compliance-checker/>





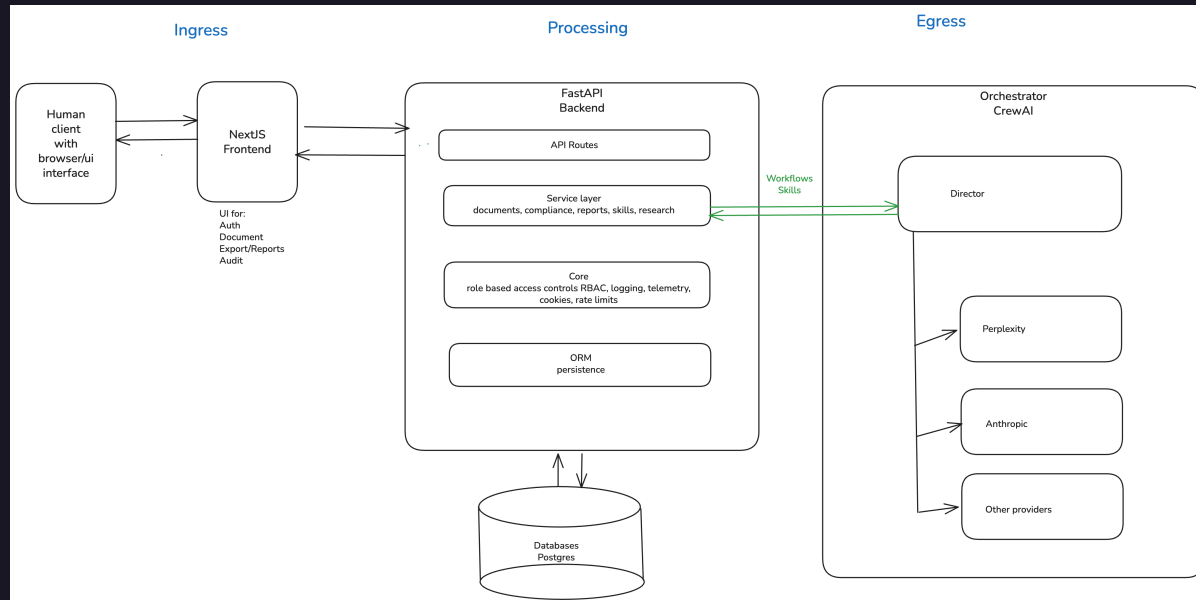
Problem solved

- Teams must prove documentation meets quality and regulatory expectations
- Manual QM review is slow, inconsistent, and hard to scale
- AI agents can help — but introduce new privacy and data-flow risks



High-level architecture

- Human operator
- Next.js frontend
- FastAPI backend
- PostgreSQL database
- Orchestrator and agents



Privacy matters

- User accounts, roles, and session data (GDPR-relevant)
- Document content and audit trails may contain sensitive business data
- Egress to LLM providers and telemetry expand the trust boundary

Top privacy risks

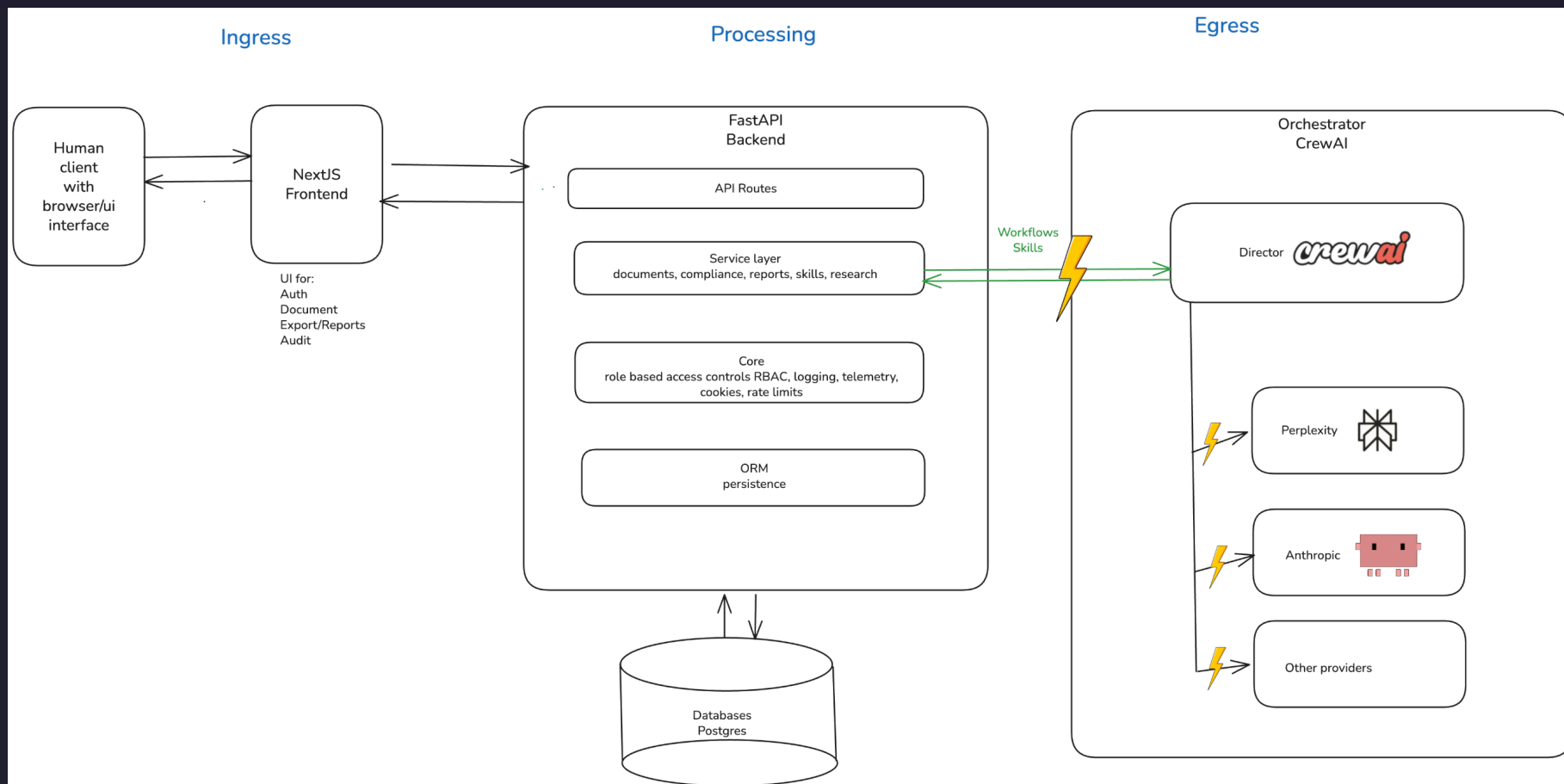
1. Egress traffic flow data to director and external models
2. Application telemetry and workflow tracing
3. Role-based access controls and GDPR compliance

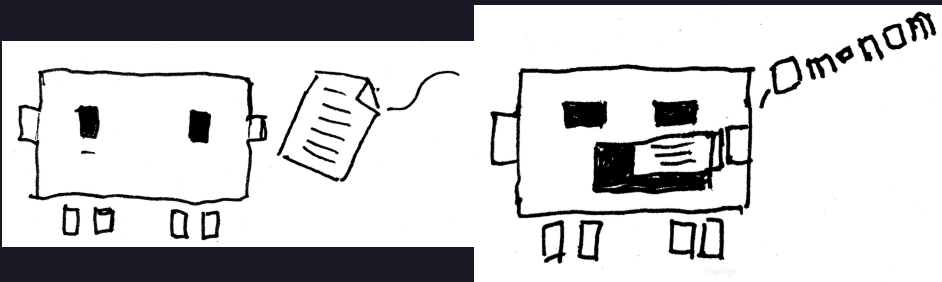
Up next: In-depth risk analysis

Let's look at each privacy risk...

- its sensitive data
- why the risk matters
- the priority of the risk
- **mitigations** of the risk

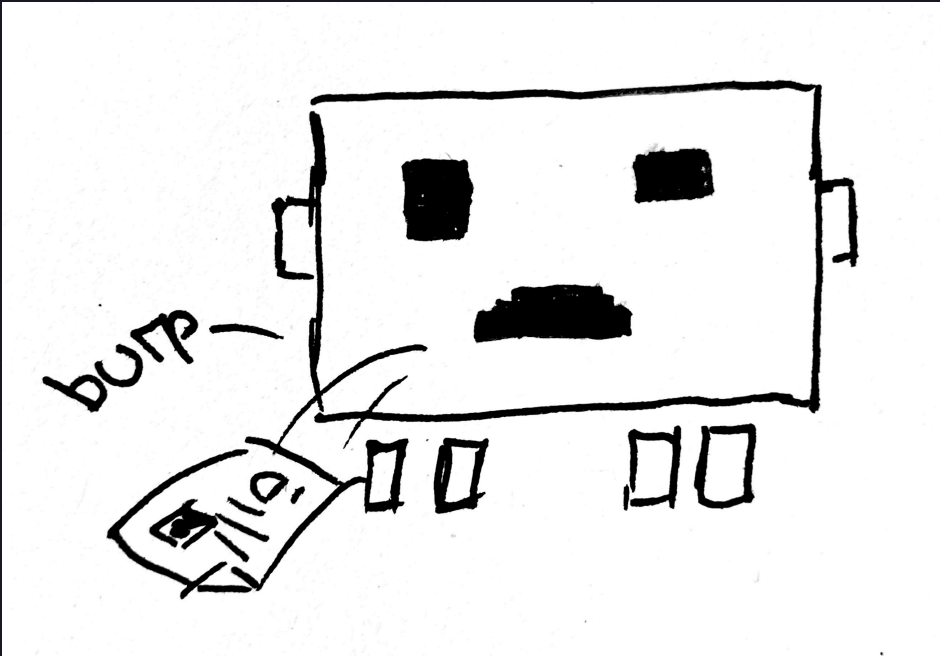
Egress exposes privacy data





Sensitive data

- External model: transfer of potentially personal prompt/output data
 - **Data:**
 - Names, emails, stakeholder assignments, reviewer identifiers, document passages copied into prompts, generated summaries that may restate personal data
 - **Why Sensitive:**
 - Leaves the primary application context during model inference (current external-provider path)



- Over-collection and -retention in model observability traces
 - **Data:**
 - provider, model_used, trace_id, correlation_id, latency/tokens, rich payload entries, prompt/output snapshots
 - **Why Sensitive:**
 - Enables reconstruction of *who* triggered *what* model action and *when*
 - can become re-identifiable when combined with audit tables

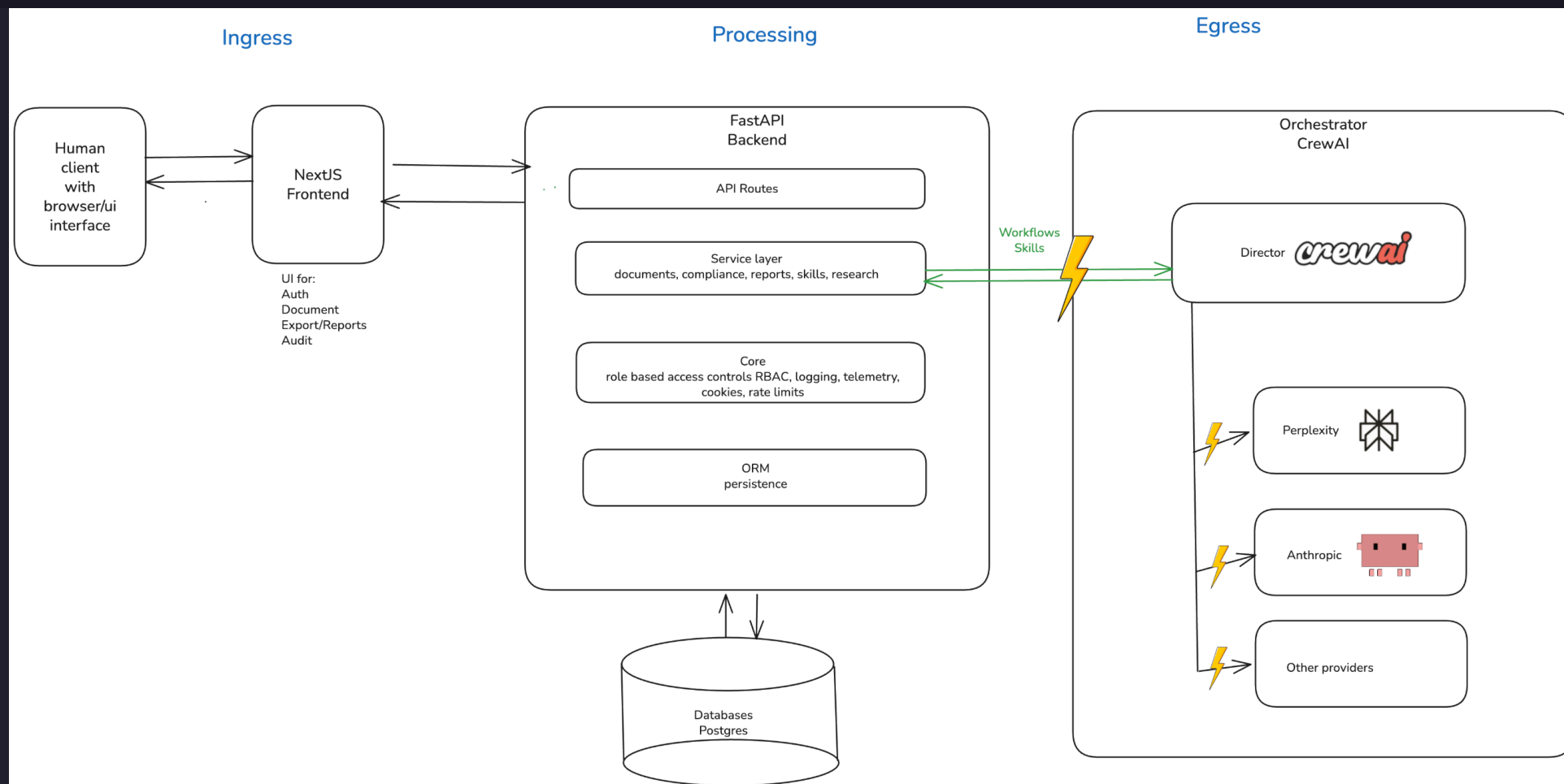


- Model credentials and routing configuration
 - **Data:**
 - API keys, adapter routing flags, provider selection settings
 - **Why Sensitive:**
 - Compromise enables data exfiltration or unauthorized model usage

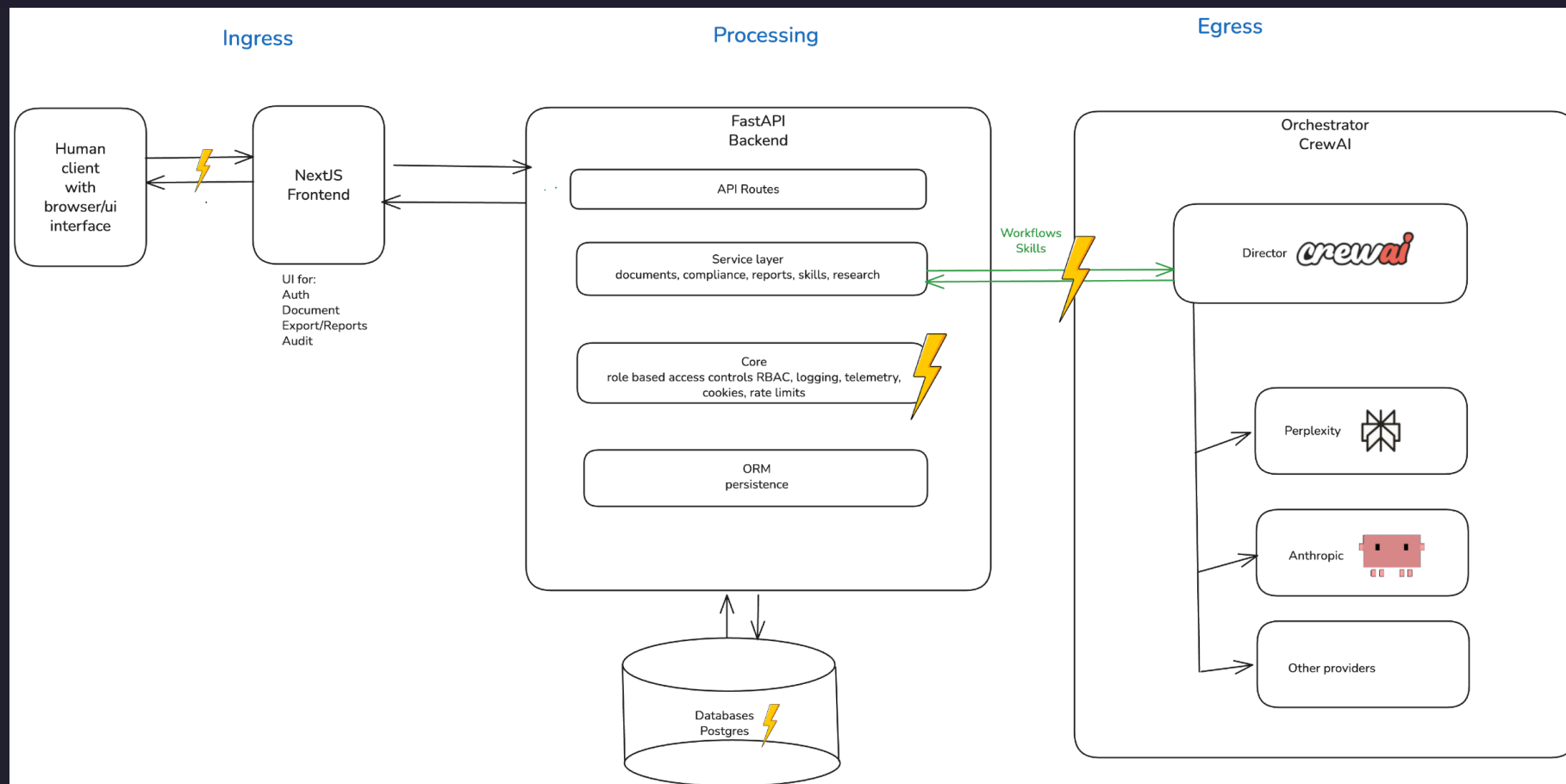
Mitigation

Egress traffic flow data to orchestrator and models

TODO: add happy mitigated image here



Audit logs/reports and telemetry expose privacy data



Sensitive data

- Raw LLM prompt and output in *quality_observations.payload*
 - **Data:**
 - *payload.provider, payload.model_used, payload.llm_temperature*
 - *payload.llm_prompt* (document text submitted by user, stakeholder names, reviewer assignments)
 - *payload.llm_output* (generated compliance summaries restating personal context)

- ○ **Why Sensitive:**
 - Prompt context is assembled from user-submitted documents which routinely contain names, emails, project identifiers, and business-sensitive content
 - The output may restate or summarise that content
 - Both are persisted to a queryable table

- Audit event payload in `audits_events.payload`
 - **Data:**
 - `payload.roles` (user role at login), `payload.remember_me` flag, event-specific context fields, any free-form data inserted by orchestrator or Skills API callers
 - **Why Sensitive:**
 - Append-only and intended for long retention
 - No technical control prevents a caller from writing personal data into the payload column
 - Combined with `actor_id` (user email) it forms a rich personal profile

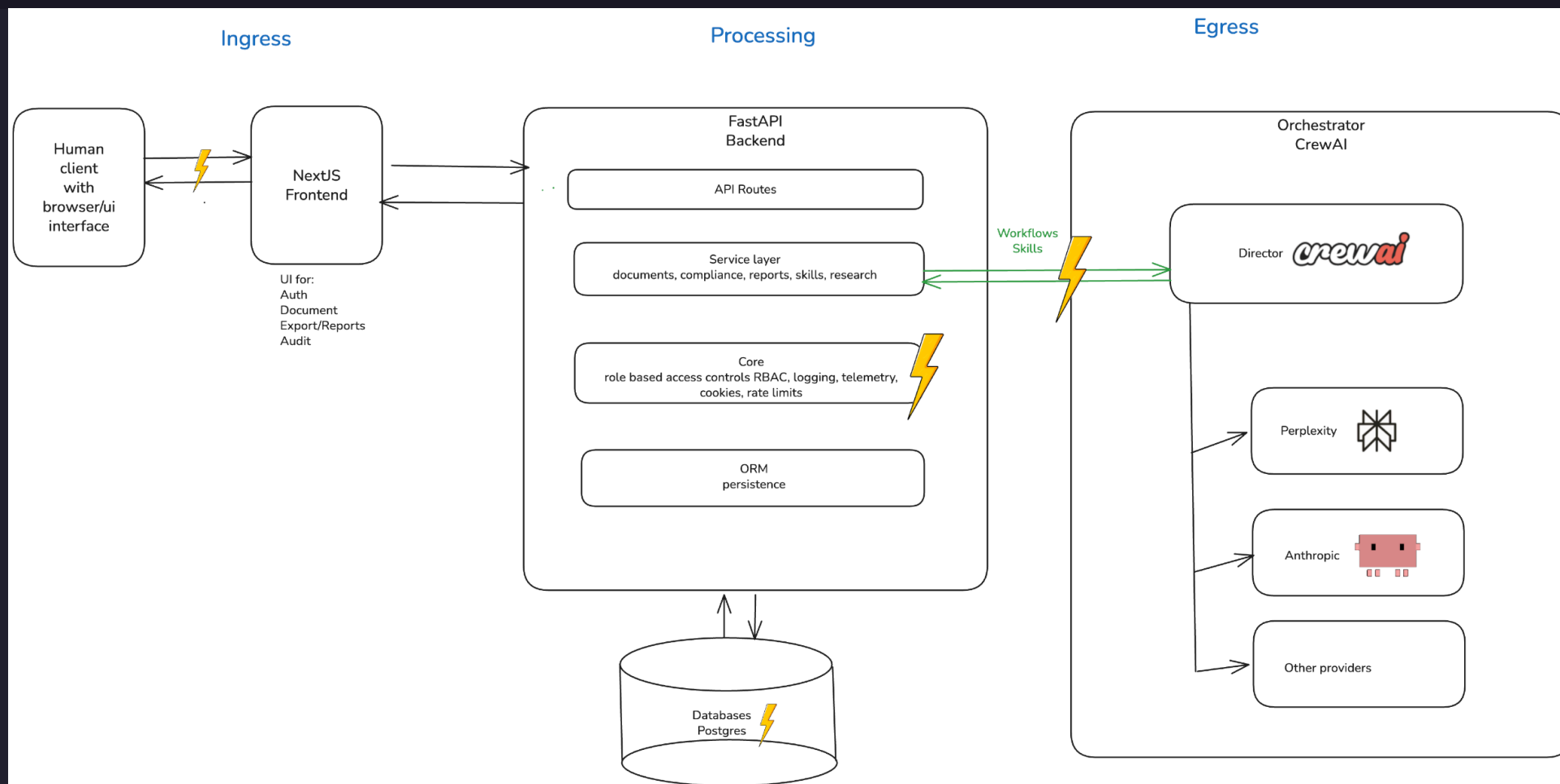
- OTEL (open telemetry) span attributes (exporter config)
 - **Data:**
 - HTTP path attribute (e.g., */api/v1/documents/doc-abc123* — document ID in path), user_agent, http.method, http.status_code, trace_id / span_id (linkable back to session)
 - **Why Sensitive:**
 - When TRACING_EXPORTER=otlp span data is sent to an external collector,
 - path values can embed document or session identifiers
 - user-agent can contribute to fingerprinting

- Frontend CSV export of prompt/output pairs
 - **Data:**
 - Exported observability *prompt_output_pairs.csv* file containing prompt, output, source_component, trace_id, timestamps
 - **Why Sensitive:**
 - Created on the user's local filesystem;
 - outside system access controls, retention policy, and audit log;
 - may contain personal data from documents processed during the export window

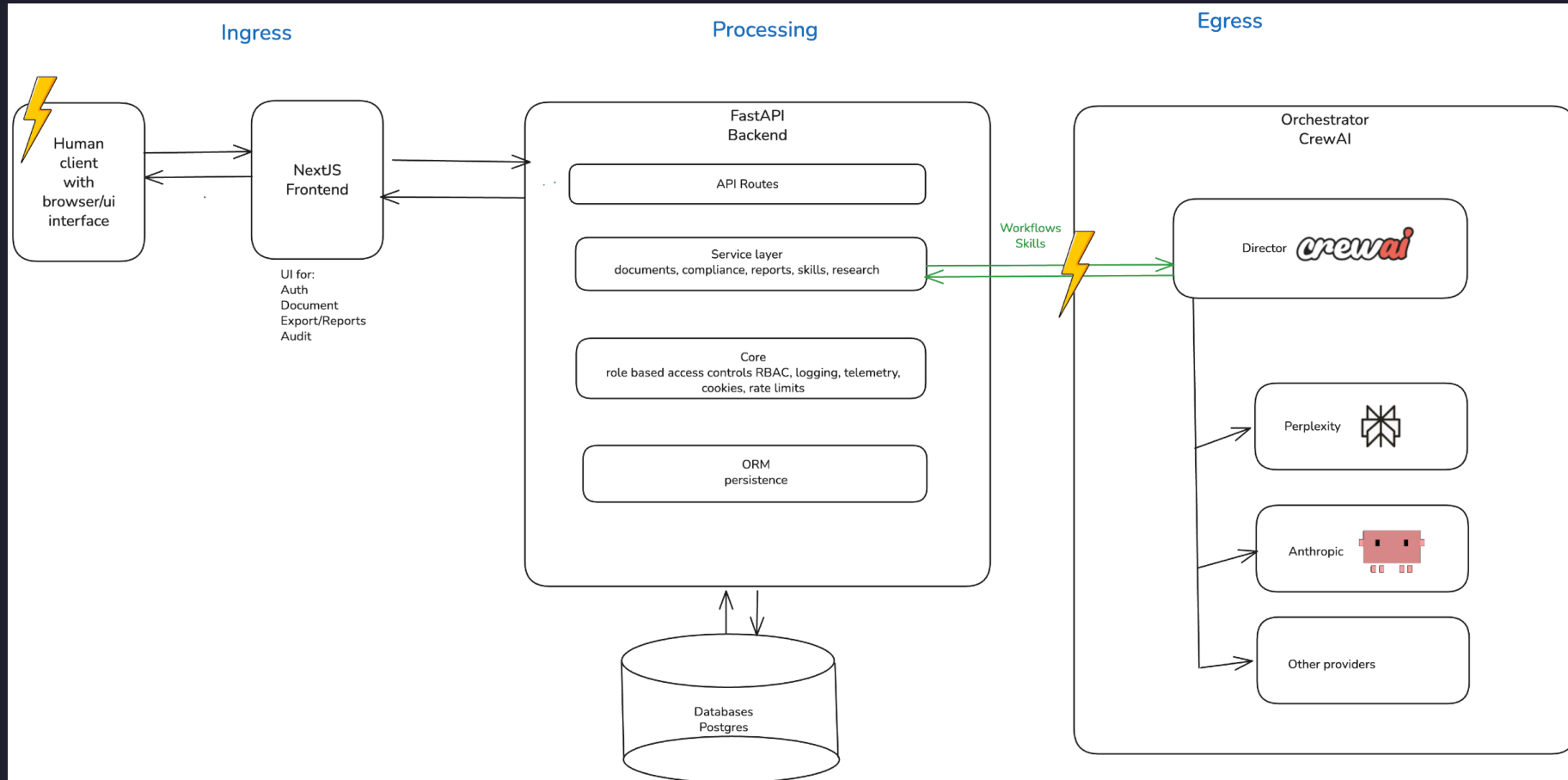
Mitigation

Application telemetry and workflow tracing

TODO: add happy mitigated image here



Misconfigured and stale controls give access to private data



Sensitive data

- User identity in session store
 - **Data:**
 - user_email (primary identifier), user_org, session session_id, expires_at, last_seen_at
 - **Why Sensitive:**
 - Directly identifies users and links their organisational role to access patterns and audit trails
 - Retained in PostgreSQL with no visible TTL-based purge policy

- Role assignments and permission scope
 - **Data:**
 - user_roles array per session row (e.g., ["qm_lead"], ["auditor"]), org isolation field
user_org
 - **Why Sensitive:**
 - Reveals organisational responsibilities and access privileges
 - Can be used for social engineering or targeted attacks
 - GDPR data minimisation applies

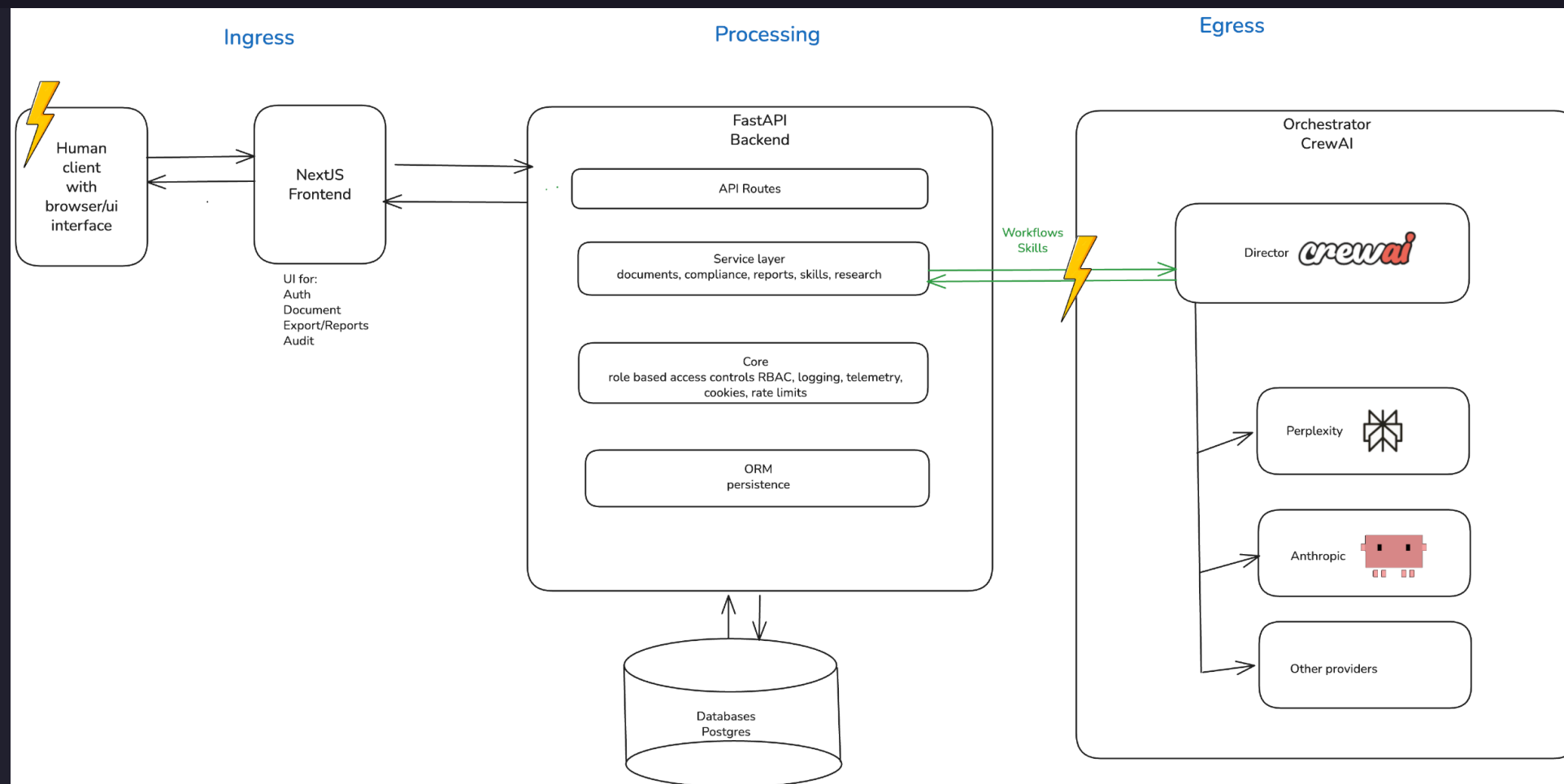
- Bootstrap/MVP credentials in environment configuration
 - **Data:**
 - AUTH_MVP_EMAIL, AUTH_MVP_PASSWORD, AUTH_MVP_ROLES, AUTH_MVP_ORG (env vars)
 - SECRET_KEY (API key secret)
 - **Why sensitive:**
 - Compromise of bootstrap credentials gives attacker a fully provisioned account with configurable roles
 - SECRET_KEY grants service-client access to skills and observability

- Access decision and audit context not separately persisted
 - **Data:**
 - Which role accessed which route at what time
 - 403 access denials
 - service-client route usage with payload summary
 - **Why sensitive:**
 - Absence of access-decision audit log prevents retrospective investigation of data-access incidents
 - Required for GDPR Art. 30 record of processing activities and breach response

Mitigation

Role-based access controls and GDPR compliance

TODO: add happy mitigated image here



Recommendations

- Top priority going forward
 - Why it matters
- Fit with company and risk strategy
 - Value created

Top priority going forward

- Meet the standard directives and too much to do manually
- Maintain tool for efficiency

Why it matters

- Insert why it is important (ROI, risk reduction, user impact, compliance, security)
- Too much for any one human to analyze 1000 page document
- Time for weeks and months for a document
- Changes if directives change
- Expensive specialists
- Basic insights, what has changed, where changed, policies affected

Fit with company and risk strategy

- GDPR / BSI in Germany regulations for software rules
- Main points are addressed for external audits

Value created

- Being audit

Questions & answers

- Audit scope and findings
- Risk prioritization and trade-offs
- Mitigations and open items

Thank you

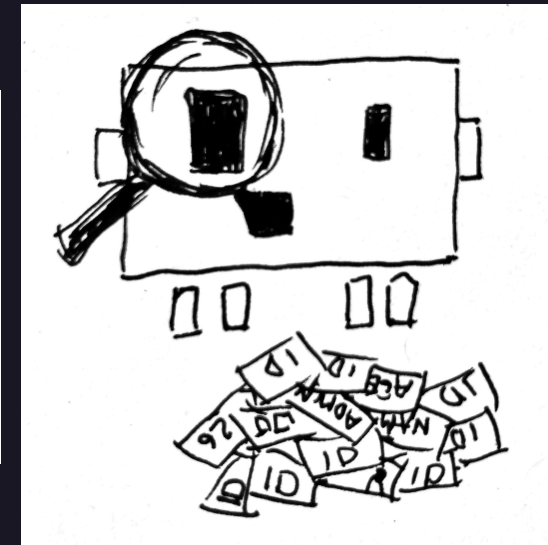
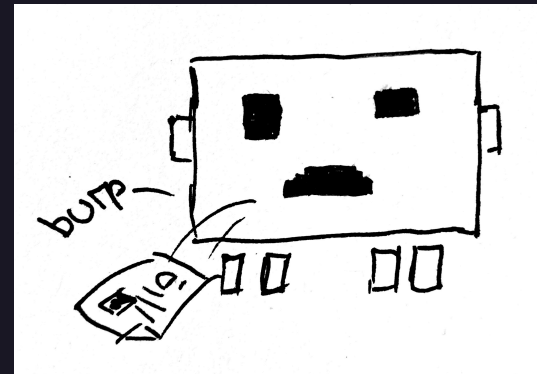
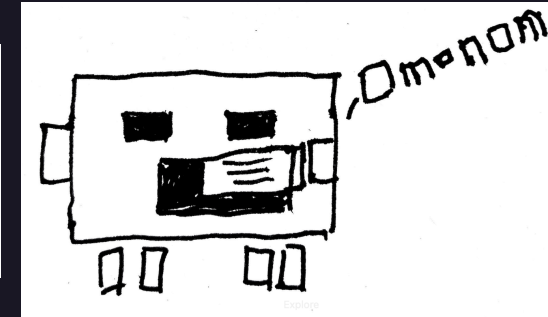
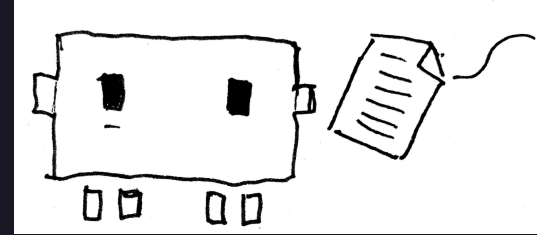
Ilona Brinkmeier · Wiebke Meyer · Carol Willing

Privacy audit

<https://willingc.github.io/compliance-checker/>

Application

https://github.com/IloBe/doc_quality_compliance_check



Appendix

- DocQuality Bridge workflow screens
 - DocQuality Admin screens
- DocQuality Compliance standards screens

Bridge workflow — orchestration



DOCQUALITY

COMPLIANCE & QA LAB

Home (Doc Hub)

Compliance Standards

STATISTICS

Dashboard

PIPELINE

Bridge

Artifact Lab

Auditor Vault

GOVERNANCE

SOPs

Risk (FMEA/RMF)

Architecture (arc42)

REPORTING

Exports Registry

Audit Trail

Auditor Workstation

SUPPORT

Help & Snippets

Q&A

Glossary

Admin

Observability

Stakeholders & Rights

Compliance Controls

AI-Assisted Tool

This application uses AI to assist document analysis and compliance checking. **Results should be verified by qualified human experts.** AI systems have limitations and may produce errors. Users remain fully responsible for all decisions and outputs.

AI model disclaimer: Llama 3.1 8B (OLLAMA) T=0.2 P=0.9 K=40

N

It accessed: 2026-05-25 01:59

ACTIVE PROJECT

All Projects

Q

Search Doc ID / Title

demo@quality-station.ai

QM_LEAD

D

BRIDGE ARCHITECTURE

Workflow Orchestration

Multi-agent orchestration pipeline for document compliance and quality analysis.

SELECT LOCAL FILE

RELOAD AGENTS

OPEN BRIDGE RUN

Select Document for Bridge Run

The selected document becomes the active document for workflow orchestration.

ACTIVE DOCUMENT

07_bridge_gdpr_security_violation_xray_complaint.pdf

3ff1f39b-052b-4ec7-8a18-55a9a3ef0d37

Dynamic Agent Routing

Live bridge runtime topology proof for orchestrator-managed, containerized agent sandboxes.

4

AGENT CONTAINERS

4

HEALTHY CONTAINERS

docker_inspect

PROOF SOURCE

INFRASTRUCTURE STATUS

Topology Proven

RUNTIME TOPOLOGY PROOF

Checked at 2026-05-25 01:59. Orchestrator: bridge-workflow-orchestrator (containerized-sandbox).

All 4 bridge agents are running in isolated orchestrated containers.

Governance note

Bridge orchestrates the controlled analysis sequence. Any downstream approval or rejection decision should reference the corresponding pipeline evidence and session trace.

AI Privacy Capstone - May 2026

38

Bridge workflow — run steps 1–2

DOCQUALITY

COMPLIANCE & QA LAB

Home (Doc Hub)

Compliance Standards

STATISTICS

Dashboard

PIPELINE

Bridge

Artifact Lab

Auditor Vault

GOVERNANCE

SOPs

Risk (FMEA/RMF)

Architecture (arc42)

REPORTING

Exports Registry

Audit Trail

Auditor Workstation

SUPPORT

Help & Snippets

Q&A

Glossary

Admin

Observability

Stakeholders & Rights

Compliance Controls

AI-Assisted Tool

This application uses AI to assist document analysis and compliance checking. Results should be verified by qualified human experts. AI systems have limitations and may produce errors. Users remain fully responsible for all decisions and

ACTIVE PROJECT

All Projects

Q Search Doc ID / Title

Load Document

Prepare source document and metadata

ACTIVE DOCUMENT UNDER INVESTIGATION

07_bridge_gdpr_security_violation_xray_complaint.pdf

3ff2f39b-852b-4ec7-ba1b-55da3ef0637

Run Controls

Evaluate compliance controls and standards

APPLICABLE CONTROLS FOR THIS RUN

EU AI Act Art. 14

MANDATORY BASELINE

PASSED

GDPR Art. 32 and NIS2

MANDATORY BASELINE

FINDINGS

IEC 62304

CONTEXT-ACTIVATED

FINDINGS

ISO/IEC 13485

CONTEXT-ACTIVATED

PASSED

ISO/IEC 14971

CONTEXT-ACTIVATED

PASSED

ISO/IEC 27001 A.5

MANDATORY BASELINE

PASSED

ISO 9001 plus Internal AI SOP

MANDATORY BASELINE

FINDINGS

MDR EU Medical Devices

CONTEXT-ACTIVATED

PASSED

DATA PRIVACY RISK STATUS

Explicit GDPR and LLM/GenAI security-violation indicators detected in bridge document context.

Detailed data privacy mitigation actions are provided in Step 4 (Produce Recommendation).

[00:18:41] Step 4: Produce Recommendation active...

[00:18:48] Step 3: Assess Findings active...

[00:18:59] Multi-framework check complete. Score: 485.

[00:18:38] Step 2: Run Controls active...

[00:18:37] Step 1: Load Document active...

[00:18:37] Initiating Bridge Run for 3ff2f39b-852b-4ec7-ba1b-55da3ef0637...

DOCQUALITY

COMPLIANCE & QA LAB

Home (Doc Hub)

Compliance Standards

STATISTICS

Dashboard

PIPELINE

Bridge

Artifact Lab

Auditor Vault

GOVERNANCE

SOPs

Risk (FMEA/RMF)

Architecture (arc42)

REPORTING

Exports Registry

Audit Trail

Auditor Workstation

SUPPORT

Help & Snippets

Q&A

Glossary

Admin

Observability

Stakeholders & Rights

Compliance Controls

AI-Assisted Tool

This application uses AI to assist document analysis and compliance checking. Results should be verified by qualified human experts. AI systems have limitations and may produce errors. Users remain fully responsible for all decisions and outputs.

AI model disclaimer: Llama 3.1 8B (OLLAMA) T=0.2 P=0.9 K=40

Last accessed: May 24, 2026

ACTIVE PROJECT

All Projects

Q Search Doc ID / Title

Assess Findings

Cross-check against references and evidence

FINDINGS BY CONTROL ITEM

EU AI ACT

Data and Data Governance

ART. 10 - PARAGRAPH NOT EXPLICITLY STATED

Data and Data Governance: Training, validation and testing datasets must meet quality criteria (Art. 10)

Record-Keeping / Logging

ART. 12 - PARAGRAPH NOT EXPLICITLY STATED

Record-Keeping / Logging: High-risk AI systems shall be designed with automatic logging capabilities (Art. 12)

Human Oversight

ART. 14 - PARAGRAPH NOT EXPLICITLY STATED

Human Oversight: Design AI systems to be effectively overseen by humans (Art. 14)

Accuracy, Robustness and Cybersecurity

ART. 15 - PARAGRAPH NOT EXPLICITLY STATED

Accuracy, Robustness and Cybersecurity: High-risk AI systems shall be resilient to errors and attacks (Art. 15)

Conformity Assessment

ART. 43 - PARAGRAPH NOT EXPLICITLY STATED

Conformity Assessment: Undertake a conformity assessment before placing on market (Art. 43)

Register in EU database

ART. 48 - PARAGRAPH NOT EXPLICITLY STATED

Register in EU database: Register high-risk AI systems in EU database before placing on market (Art. 49)

CRA CYBER RESILIENCE ACT

Secure-by-Design Product Controls

CRA-SECURE-BY-DESIGN - PARAGRAPH NOT EXPLICITLY STATED

Secure-by-Design Product Controls: Document secure-by-design and vulnerability handling controls under the EU CRA.

Component and Vulnerability Transparency

CRA-SBOM - PARAGRAPH NOT EXPLICITLY STATED

Component and Vulnerability Transparency: Maintain component and known-vulnerability transparency for digital products.

Bridge workflow — run steps 4–4b

Produce Recommendation

Generate decision summary for HITL review

FINAL RESULT SUMMARY

QUALITY GATE SUMMARY - REJECTED

Violations detected. Mandatory gaps: 15. Optional gaps: 1. Privacy violation: yes.

MITIGATIONS FOR FOUND CONTROL ISSUES

Strengthen monitoring and incident response

Add structured logging, alert thresholds, and incident-response playbooks for bridge-critical paths. Attach log samples, alert test evidence, and incident drill results. Affected controls: EUAIA-4 (eu_ai_act), NIS2-REPORTING (nis2).

Update risk-treatment controls

Re-assess identified risks, define treatment owners/due dates, and verify residual-risk acceptance through formal review. Attach risk register updates and governance approval evidence. Affected controls: EUAIA-7 (eu_ai_act), EUAIA-8 (eu_ai_act), EUAIA-9 (eu_ai_act), ISO14971-4 (iso_14971).

Reinforce lifecycle validation evidence

Execute targeted verification and validation for affected components before rerun. Attach test protocol, execution results, and release readiness decision. Affected controls: BSI-TR03185-SDLC-1 (bsi_tr_03185), BSI-TR03185-SDLC-2 (bsi_tr_03185), EUAIA-2 (eu_ai_act), IEC62304-5 (iec_62304) (+1 more).

Close governance and evidence traceability gaps

Update SOP/policy artifacts and map each control to concrete implementation evidence. Attach revised documents, traceability matrix, and review records. Affected controls: BSI-GS-ORP (bsi_grundschutz), CRA-SECURE-BY-DESIGN (cra_cyber_resilience_act), EUAIA-6 (eu_ai_act).

DATA PRIVACY RISK MITIGATION ACTIONS

Apply deterministic PHI/PII redaction before model invocation

PROPOSED

Mask names, addresses, age/sex markers, and hospital identifiers before any LLM/GenAI step.

Planned: enforce pre-inference redaction stage across all sensitive bridge paths.

Enforce local-only sandbox execution for all bridge agent steps

IMPLEMENTED

Run inspection, compliance, research, and quality-gate agents in separate local sandboxes with external egress denied.

Implemented: bridge runtime enforces local ollama-only execution with deny_external egress checks.

Block persistence of raw prompt/output containing sensitive health context

PROPOSED

Store only redacted, schema-validated artifacts and retain full traces only in short-lived restricted stores.

Planned: stricter persistence minimization and retention-tier controls for prompt/output artifacts.

Require human approval for repeated-risk incidents

IMPLEMENTED

Automatically route bridge runs with repeated mitigation failure to mandatory reviewer rejection/approval workflow.

Implemented: bridge runs require mandatory human HITL approval/rejection workflow with auditable decisions.

Bridge workflow — run step 5

BRIDGE / WORKFLOW



07_bridge_gdpr_security_violation_xray_complaint.pdf ⓘ

LIVE SESSION

EXIT WORKFLOW

EXECUTE BRIDGE RUN

Document compliance session ID: 3ff1f39b-052b-4ec7-8a10-55a9a3ef0d37

Bridge run completed. Human HITL review is required.

Backend mode: multi-framework compliance checks are executed via API and persisted with run evidence.

MANDATORY HITL REVIEW

Human approval is required before final acceptance

PENDING HUMAN ACTION

Automatic recommendation: REJECTED

APPROVE

REJECT

REASON (REQUIRED)

Document your approval/rejection rationale for audit reproducibility.

NEXT TASK PROPOSAL

Another automatic bridge run

TASK INSTRUCTIONS

Optional remediation instructions

SUBMIT HUMAN REVIEW DECISION

Admin — governance & access control

ADMIN / GOVERNANCE

Compliance Controls & Policies ⓘ

Operational control baseline for policy lifecycle, evidence completeness, and framework accountability.

Auth bootstrap healthy

2 account(s) configured, admin login active.

CONTROL COVERAGE

92%

Compliant

EVIDENCE FRESHNESS

81%

Needs Attention

OPEN REMEDIATION ACTIONS

4

Needs Attention

CRITICAL CONTROL GAPS

0

Compliant

Policy Registry

Policy ownership and review cadence tracking for controlled admin processes.

Policy	Owner	Review	Status
Access Control and Role Governance v1.8	Security Governance Board	Quarterly Next: 2026-07-15	Compliant
AI Quality and Hallucination Management v1.4	QM Lead Office	Monthly Next: 2026-06-05	Needs Attention
Audit Traceability and Evidence Retention v2.1	Compliance Operations	Quarterly Next: 2026-08-01	Compliant
Incident Response and Escalation v0.9	Platform Reliability Team	Monthly Next: 2026-05-28	Draft

Control Implementation Matrix

End-to-end mapping from framework objective to implementation evidence.

ADD CONTROL ITEM (APP ADMIN / QM LEAD)

Control name

Framework label (e.g. GDPR Art. 32)

Framework id (e.g. gdpr)

Directive

Context

medical

eu

Draft

Objective

Implementation

Evidence

ADD CONTROL ITEM

Human-in-the-loop approval gate

EU AI Act Art. 14 - baseline - directive

Objective

Require accountable human review before regulated release decisions.

Compliant

ACTIVE PROJECT

All Projects

Search Doc ID / Title

demo@quality-station.ai

ADMIN / ACCESS GOVERNANCE

Stakeholder Profiles & Authorization Rights ⓘ

Configure role templates used for controlled access in compliance workflows.

Auth bootstrap healthy

2 account(s) configured, admin login active.

Role Profiles

Model Policy

PROFILES

App Admin

app_admin

Architect

architect

Auditor

auditor

QM Lead

qm_lead

Risk Manager

riskmanager

Service Client

service

App Admin

Maintains user-role mapping and model/runtime policy configuration.

Save template

TITLE

App Admin

DESCRIPTION

Maintains user-role mapping and model/runtime policy configuration.

Active profile

Inactive profiles remain stored but can be excluded by admin queries.

Compliance Check Read

compliance.check.read

Compliance Check Write

compliance.check.write

Model Policy Read

model.policy.read

Model Policy Write

model.policy.write

Audit View

audit.view

Risk Assessment Read

risk.assessment.read

Risk Assessment Write

risk.assessment.write

Bridge Run Write

bridge.run.write

Architecture Read

architecture.read

Stakeholder Profiles Write

stakeholder.profiles.write

ASSIGNED EMPLOYEES

AI Privacy Capstone - May 2026

42

Compliance standards — mandatory & optional

GOVERNANCE & STANDARDS

Compliance Standards ⓘ

This page lists the regulatory standards and mappings used for governance checks. The framework-agnostic bridge execution layer supports compliance frameworks with intelligent domain-based conditional activation.

Always-On Frameworks

Baseline governance applied across all product domains and business contexts.

7 FRAMEWORKS

EU AI Act ⓘ ⓘ

Primary regulatory baseline for AI system classification, obligations, and conformity expectations in the EU market.

Agent Verified ⓘ

ISO/IEC 9001 ⓘ

Quality management system baseline for documented processes, traceability, and continuous improvement.

Agent Verified ⓘ

ISO/IEC 27001:2022 ⓘ

Information security management baseline for controls, asset protection, and risk-driven safeguard verification.

Agent Verified ⓘ

ISO 31000 ⓘ

Risk management framework for identifying, evaluating, and treating operational and product-level risks.

Agent Verified ⓘ

PERPLEXITY RESEARCH WATCH ACTIVE

Recent Compliance Alerts ⓘ

No active alerts.

VIEW ALERT ARCHIVE ⓘ

Conditionally Activated Frameworks

Additional regulatory requirements activated based on product domain, market, or business context.

OPTIONAL

Frameworks enabled for specific operational or contractual contexts.

HIPAA ⓘ ⓘ

Healthcare privacy and security obligations activated for protected health information and US healthcare operations.

Agent Verified ⓘ

MEDICINE

Standards activated for medical device, clinical, and healthcare software delivery contexts.

ISO/IEC 13485 ⓘ ⓘ

Medical device quality management standard for controlled development, validation, and lifecycle evidence.

Agent Verified ⓘ

ISO/IEC 14971 ⓘ ⓘ

Medical device risk management standard for hazard analysis, residual risk evaluation, and safety evidence.

Agent Verified ⓘ

AI Privacy Capstone - May 2026

43